Project Title:

ISO 27001/IEC:2022 Information Security Risk Management for ABC Supermarket Ltd.

1. Company Profile

Organization Information

Company Name: ABC Supermarket Ltd.

Industry: Retail (Supermarket)

Headquarters: Berlin, Germany

Business Model: Retail grocery and household products

Established: 2015 (Fictional)

Employees: 4,800

Retail Stores: 185

Distribution Centers: 3

Annual Customer Transactions: Approximately 10 million

IT Staff: 75

Cybersecurity Team: 8

Business Operations

- Physical supermarket stores
- Online shopping website
- Mobile shopping application
- Home delivery services
- Warehouse management
- Supply chain operations

2. Business Objective

ABC Supermarket processes millions of customer transactions annually. The company relies heavily on secure IT systems to support retail operations, online shopping, logistics, payment processing, and customer data management.

To improve information security and align with international best practices, management has decided to implement an **ISO 27001 Information Security Management System (ISMS).**

3. Project Scope

The ISMS covers:

Included

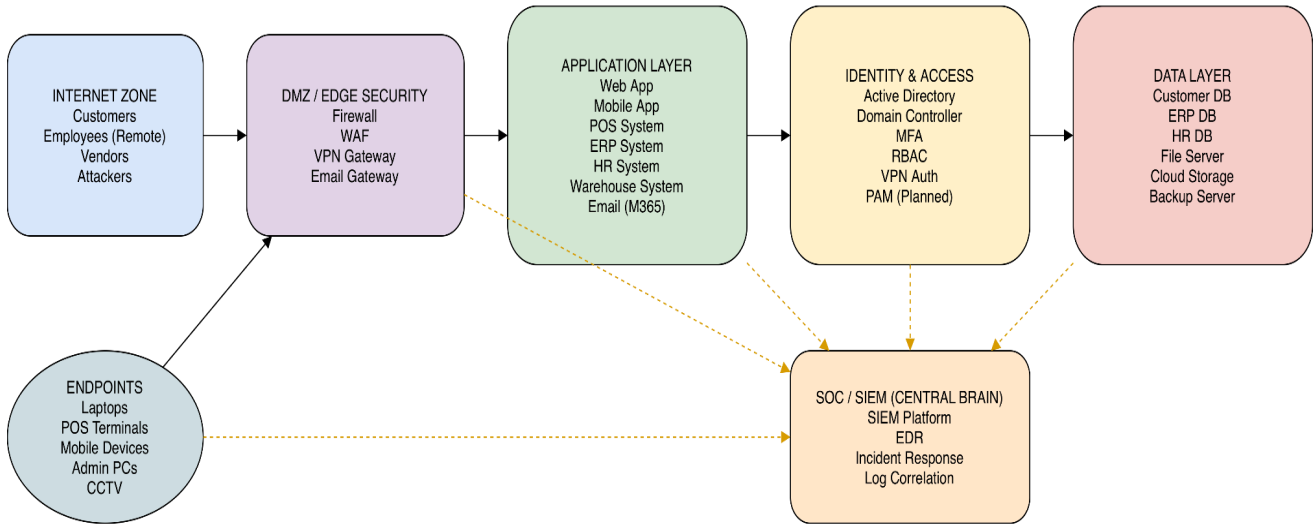
- Corporate headquarters
- Retail stores
- Point of Sale (POS) systems
- Customer database
- ERP system
- HR system
- Email services
- Active Directory
- Microsoft 365
- Cloud infrastructure
- Network infrastructure
- VPN
- Employee laptops
- Backup systems

Excluded

- Third-party delivery partners' internal infrastructure
- Customer personal devices
- External supplier internal systems

System / Security Architecture

This architecture represents a layered security model for ABC Supermarket aligned with ISO/IEC 27001:2022, where external users (customers, employees, vendors) access internal systems through a secured DMZ containing firewall, WAF, VPN, and email gateway controls. Business applications such as the web app, mobile app, POS, ERP, and HR systems operate in the application layer and rely on the identity layer (Active Directory, MFA, RBAC) for authentication and authorization before accessing the data layer, which stores critical assets like customer, ERP, and HR databases with encryption and backup protection. All systems are connected through a secured network infrastructure and continuously monitored by a centralized SOC using SIEM and EDR, which collects logs from endpoints, applications, and network devices to detect and respond to threats in real time.



4. Business Assets

Asset ID	Asset	Category	Owner	Criticality
A001	Customer Database	Information	IT Manager	Critical
A002	POS System	Application	Retail Operations	Critical
A003	ERP System	Application	Finance	Critical
A004	Warehouse System	Application	Logistics	High
A005	HR System	Information	HR	High
A006	Microsoft 365	Cloud Service	IT	High
A007	Active Directory	Infrastructure	IT	Critical
A008	Firewall	Infrastructure	Network Team	Critical
A009	Backup Server	Infrastructure	IT	Critical
A010	Employee Laptops	Endpoint	IT	Medium
A011	VPN Gateway	Infrastructure	Network Team	High
A012	Cloud Storage	Cloud Service	Cloud Administrator	High
A013	Payment Gateway	Application	Finance	Critical
A014	Email Server	Application	IT	High
A015	File Server	Infrastructure	IT	High
A016	Corporate Wifi Network	Network	Network Team	High
A017	Domain Controller	Infrastructure	IT	Critical
A018	Customer Mobile Application	Application	Digital Team	High
A019	Web Server	Infrastructure	IT	Critical

A020	CCTV Security System	Infrastructure	Facilities	Medium

5. Threat Identification

Threat ID	Threat
T01	Phishing Attack
T02	Ransomware
T03	Insider Threat
T04	Data Breach
T05	DDoS Attack
T06	Malware Infection
T07	Cloud Misconfiguration
T08	Weak Passwords
T09	Unauthorized Access
T10	Vendor Compromise
T11	Configuration Error
T12	SQL Injection
T13	Credential Theft
T14	Brute Force Attack
T15	Privilege Escalation
T16	Hardware Failure
T17	Power Outage
T18	Data Loss
T19	Lost or Stolen Device
T20	Email Spoofing

6. Vulnerabilities

ID	Vulnerability
V01	Lack of Multi-Factor Authentication
V02	Weak Password Policy
V03	Unpatched Systems
V04	Excessive User Privileges
V05	Lack of Security Awareness Training
V06	Poor Network Segmentation
V07	Misconfigured Cloud Storage
V08	Weak Backup Testing
V09	Outdated Antivirus
V10	Insecure API Configuration
V11	Open Firewall Ports
V12	Missing Encryption
V13	Unsupported Operating System
V14	Lack of Monitoring
V15	Weak Physical Security

7. Step 1 : Define Likelihood Scale

Likelihood	Description	Example
1	Rare	Very unlikely to happen
2	Unlikely	Could happen but not often
3	Possible	May happen occasionally
4	Likely	Happens regularly in similar organizations
5	Almost Certain	Expected to occur if no controls exist

Step 2: Define Impact Scale

Impact	Description	Business Effect
1	Negligible	No business disruption
2	Minor	Small financial or operational impact
3	Moderate	Noticeable service disruption
4	Major	Significant financial or reputational damage
5	Catastrophic	Severe business interruption, legal penalties, major data loss

Step 3: Calculate Risk Score

Use: Risk Calculation Formula

Risk Score = Likelihood × Impact

Step 4: Risk Levels

Score	Level
1–5	Low
6–10	Medium
11–15	High
16–25	Critical

Step 5: Risk Assessment Criteria

Risk Level	Decision
Low	Accept
Medium	Monitor or Mitigate
High	Mitigate
Critical	Immediate Mitigation

8. Risk Register

ID	Asset	Threat	Vulnerability	L	I	Score	Level	Risk Owner
R001	POS System	Ransomware	Unpatched systems	5	5	25	Critical	Retail IT Manager
R002	Customer Database	Data Breach	Missing MFA	4	5	20	Critical	Data Protection Officer (DPO)
R003	Microsoft 365	Phishing	Security awareness gaps	5	4	20	Critical	IT Security Team
R004	ERP	Unauthorized Access	Excessive privileges	3	5	15	High	Finance IT Manager
R005	Cloud Storage	Misconfiguration	Public storage	4	5	20	Critical	Cloud Administrator
R006	Warehouse System	Malware	Outdated antivirus	3	4	12	High	Logistics IT Co-ordinator
R007	Firewall	Configuration Error	Poor change management	2	5	10	Medium	Network Security Team
R008	Employee Laptop	Malware	USB usage	3	3	9	Medium	IT Support Manager
R009	VPN	Credential Theft	Weak password	4	4	16	Critical	Network Security Team
R010	Backup Server	Backup Failure	No restore testing	3	5	15	High	IT Infrastructure Engineer
R011	Customer Mobile App	SQL Injection	Insecure API Configuration	4	5	20	Critical	Digital Development Team Lead
R012	Email Server	Email Spoofing	Missing SPF/DKIM/DMARC	4	4	16	Critical	Messaging/Email Administrator
R013	Active Directory	Privilege Escalation	Excessive Privileges	4	5	20	Critical	IAM Team

R014	VPN Gateway	Brute Force Attack	Weak Password Policy	4	4	16	Critical	Network Security Team
R015	File Server	Data Loss	Missing Encryption	3	5	15	High	IT Infrastructure Manager
R016	Payment Gateway	Vendor Compromise	Third-party Dependency	3	5	15	High	Finance IT Security
R017	Web Server	DDoS Attack	Lack of Rate Limiting	4	4	16	Critical	Web Operations Team
R018	Corporate Wi-Fi	Unauthorized Access	Weak Wi-Fi Security	3	4	12	High	Network Engineer Team
R019	Employee Laptop	Lost Device	No Disk Encryption	3	4	12	High	IT Support Manager
R020	CCTV System	Hardware Failure	No Preventive Maintenance	2	3	6	Medium	Facilities Security Manager

9. Risk Treatment Plan

Risk	Treatment
Ransomware	Deploy EDR, Patch Management
Phishing	MFA, Email Filtering, Security Awareness Training
Data Breach	RBAC, Encryption
Cloud Misconfiguration	Cloud Security Review
Unauthorized Access	Quarterly Access Reviews
Backup Failure	Quarterly Restore Testing
SQL Injection	Secure Coding, WAF, Input Validation
Email Spoofing	SPF, DKIM, DMARC
Privilege Escalation	Least Privilege, PAM
Brute Force Attack	Account Lockout, MFA
Data Loss	Encryption, DLP
DDoS	CDN, DDoS Protection Service
Lost Device	Full Disk Encryption, MDM
Hardware Failure	Preventive Maintenance, Redundant Hardware

10. ISO 27001 Annex A Control Mapping

Annex A Control	Status	Evidence
Information Security Policies	Implemented	Security Policy
Asset Management	Implemented	Asset Register
Identity & Access Management	Partial	MFA rollout
Logging & Monitoring	Implemented	SIEM
Backup	Implemented	Backup Reports
Supplier Security	Partial	Vendor Assessments
Incident Management	Implemented	IR Plan

11. Statement of Applicability (SoA)

The Statement of Applicability (SoA) is a mandatory document required by ISO/IEC 27001:2022. It identifies the information security controls selected from Annex A based on the organization's risk assessment and risk treatment process. The SoA provides justification for the applicability of each control, indicates its implementation status, and serves as evidence that appropriate security measures have been selected to address the identified information security risks.

For ABC Supermarket Ltd., the Statement of Applicability was prepared by reviewing the risks identified in the Risk Register and mapping the corresponding Annex A controls to support the implementation of the Information Security Management System (ISMS). The selected controls aim to protect the confidentiality, integrity, and availability of the organization's information assets while supporting business continuity, regulatory compliance, and the overall security objectives of the organization.

The table below presents the applicable ISO/IEC 27001:2022 Annex A controls, their implementation status, and the supporting evidence for each control.

Annex A Control	Control Description	Applicable	Implementation Status	Justification / Evidence
A.5.1	Information Security Policies	Yes	Implemented	Approved Information Security Policy
A.5.9	Inventory of Information and Other Associated Assets	Yes	Implemented	Asset Register maintained
A.5.19	Information Security in Supplier Relationships	Yes	Partially Implemented	Vendor assessments performed annually
A.5.23	Information Security for Use of Cloud Services	Yes	Partially Implemented	Cloud security review in progress
A.5.30	ICT Readiness for Business Continuity	Yes	Implemented	Backup and Disaster Recovery Plan
A.6.3	Information Security Awareness, Education and Training	Yes	Partially Implemented	Annual awareness training planned
A.8.2	Privileged Access Rights	Yes	Partially Implemented	Least privilege implemented; PAM planned
A.8.3	Information Access Restriction	Yes	Implemented	Role-Based Access Control (RBAC)
A.8.5	Secure Authentication	Yes	Partially Implemented	MFA deployment ongoing
A.8.15	Logging	Yes	Implemented	SIEM collects security logs
A.8.16	Monitoring Activities	Yes	Implemented	Continuous monitoring through SIEM
A.8.24	Use of	Yes	Implemented	Encryption for

	Cryptography			sensitive data and backups
A.8.25	Secure Development Life Cycle	Yes	Partially Implemented	Secure coding practices being adopted
A.8.28	Secure Coding	Yes	Partially Implemented	Input validation and code review process
A.8.31	Separation of Development, Test and Production Environments	Yes	Implemented	Separate environments maintained

12. Conclusion

ABC Supermarket Ltd. successfully completed an Information Security Risk Management assessment in accordance with the principles of ISO/IEC 27001:2022.

The assessment identified critical business assets, evaluated relevant threats and vulnerabilities, and assessed risks using a structured methodology based on likelihood and business impact. A total of **20 key risks** were documented in the Risk Register.

The assessment highlighted several critical risks, including ransomware attacks on the POS system, customer data breaches, phishing attacks targeting Microsoft 365, cloud storage misconfigurations, SQL injection attacks against the customer mobile application, and privilege escalation within Active Directory. Appropriate risk treatment plans were developed to reduce these risks through technical and organizational controls such as multi-factor authentication (MFA), Endpoint Detection and Response (EDR), encryption, Web Application Firewalls (WAF), Privileged Access Management (PAM), backup testing, and security awareness training.

The implemented and planned controls were mapped against the relevant ISO/IEC 27001:2022 Annex A controls through the Statement of Applicability (SoA), demonstrating alignment with international information security best practices.

By implementing the recommended controls and continuously monitoring and reviewing risks, ABC Supermarket Ltd. will strengthen the confidentiality, integrity, and availability of its information assets, improve resilience against cyber threats, support regulatory compliance, and enhance customer trust.